Domain Controller Configuration Baseline and Deviation Register (HPMG, practice document)

Harbor Point Medical Group (HPMG) and all people named are fictional. This document exists only for assessment practice.

1. Document control

Item	Value
Document ID	HPMG-STD-CM-001
Version	1.0
Owner (designated official)	Information Security Officer (ISO)
Approved by	Director of IT (System Owner) and ISO
Effective date	2026-11-06
Next scheduled review	2027-11-06
Classification	Internal
Related documents	HPMG-POL-AU-001 Audit and Accountability Policy; HPMG-POL-AC-001 Access Control Policy; HPMG-PRO-IA-001 Authenticator Management Procedure

Remediation note. This baseline was written on 2026-11-06 to correct a finding from the DC01 assessment (POAM-010, control CM-6). No documented baseline existed when the assessment was performed. This document is remediation, not evidence that a baseline was in place, and it does not change that finding. The finding closes only after the baseline is applied and retested.

2. Purpose and scope

This standard sets the approved configuration settings for HPMG domain controllers, so that the settings are known, consistent and checked. It applies to DC01 (Windows Server 2022, domain ad.northstar.test) and to any domain controller added later.

HPMG uses the Microsoft Security Baseline for Windows Server 2022 as its reference and selects the settings in Section 4. The settings are the most restrictive that HPMG can use without breaking required services. Where DC01 differs from a setting below, HPMG records a deviation in Section 6.

3. Roles

Role	Responsibility
Information Security Officer	Owns this standard, keeps the deviation register, reviews the baseline every 12 months and after incidents or assessment findings.
System Owner (Director of IT)	Accountable for DC01 matching the baseline. Chairs the change control board.
System Administrators	Apply settings through Group Policy, verify them, and keep the evidence.
Change control board	Approves changes to settings in Section 4 before they are made.

4. Baseline settings

The Status column shows how DC01 stood on 2026-11-06 (evidence EV-0054 and EV-0055). "Meets" means the current value equals the baseline value.

No.	Setting	Baseline value	Applied through	Status on 2026-11-06
1	Minimum password length	14 characters	Default Domain Policy	Meets

No.	Setting	Baseline value	Applied through	Status on 2026-11-06
2	Password history	24 passwords	Default Domain Policy	Meets
3	Maximum password age	42 days	Default Domain Policy	Meets
4	Minimum password age	1 day	Default Domain Policy	Meets
5	Password complexity	Enabled	Default Domain Policy	Meets
6	Account lockout	5 attempts, 15 minute duration, 15 minute reset	Default Domain Policy	Meets
7	Reversible password encryption; LAN Manager hash storage	Disabled	Default Domain Policy	Meets
8	Logon legal notice (caption and text)	Approved HPMG notice	HPMG-DC-Security-Settings	Meets
9	Inactivity limit	900 seconds	HPMG-DC-Security-Settings	Meets
10	SMB server signing	Required	Default Domain Controllers Policy	Meets
11	Netlogon secure channel signing or sealing	Required	Default Domain Controllers Policy	Meets
12	LDAP server signing	Require signing	Default Domain Controllers Policy	Does not meet (DEV-001)
13	Allow log on locally	Administrators and Enterprise Domain Controllers only	Default Domain Controllers Policy	Does not meet (DEV-002)

No.	Setting	Baseline value	Applied through	Status on 2026-11-06
14	Advanced audit subcategories	As in HPMG-POL-AU-001 Section 6	HPMG-DC-Security-Settings	Effective, but set locally on DC01 (DEV-003)
15	Security log size	1 GB	HPMG-DC-Security-Settings	Effective, but set locally (DEV-003)
16	Security log retention	Archive the log when full	HPMG-DC-Security-Settings	Effective, but set locally (DEV-003)
17	Windows Update through the HPMG update server	Scheduled automatic install	WSUS-Infrastructure	Meets

5. Applying and verifying settings

1. A System Administrator applies every setting in Section 4 through the GPO shown in the table. Settings are not set by hand on a domain controller, except in an emergency recorded under Section 7.
2. After any change, and at least every month, the administrator runs the commands below and saves the output with its SHA-256 hash.
3. The ISO compares the output with Section 4 and records any difference as a deviation.

Verification commands: `Get-GPO -All`, `gpresult /scope computer /v`, `auditpol /get /category:*` and `wevtutil gl Security`.

6. Deviations

A deviation is any setting that differs from Section 4. It is allowed only if it is recorded below with the reason, the risk, the decision, an end date and an approval from the ISO and the System Owner. A deviation without an end date is not allowed. The ISO reviews the register monthly.

ID	Setting	Baseline value	Current value	Reason and risk	Decision and end date	Approved by (fictional)
DEV-001	LDAP server signing	Require signing	Negotiate signing	Clients have not yet been tested with required signing. Risk: Moderate. Unsigned LDAP traffic can be altered or relayed on the network.	Temporary. Test clients and set to Require signing by 2026-12-04.	ISO and Director of IT, 2026-11-06
DEV-002	Allow log on locally	Administrators and Enterprise Domain Controllers	Also Account, Backup, Print and Server Operators	Default setting inherited from the Default Domain Controllers Policy. Membership of these operator groups has not yet been verified. Risk: Moderate. Members could sign in at the domain controller console.	Temporary. Verify membership and remove the operator groups by 2026-12-04.	ISO and Director of IT, 2026-11-06
DEV-003	Audit subcategories, Security log size and retention	Set in HPMG-DC-Security-Settings	Set locally on DC01	Applied with auditpol and wevtutil during remediation of POAM-009. Risk: Low. The settings are correct now but would be lost on a rebuilt or added domain controller.	Temporary. Move into the GPO by 2026-11-20.	ISO and Director of IT, 2026-11-06

7. Change control

1. Every change to a setting in Section 4 needs a change ticket, numbered CHG-0001 and up, approved by the change control board before the change is made.
2. A ticket records: what changes and why; the setting, old value and new value; the risk; who approves; the date and time; the rollback steps; and the verification evidence.
3. In an emergency the administrator makes the change, and the ticket is raised within one business day.
4. Each week the ISO lists the GPOs with their last modified times (`Get-GPO -All`) and checks that every change has a ticket. A change without a ticket is recorded as an incident and a deviation.
5. Approved changes update Section 4 and the revision history.

8. Review and approval

The ISO reviews this standard every 12 months and after any security incident, major system change or assessment finding that shows a gap.

Revision history

Version	Date	Author	Summary
1.0	2026-11-06	Information Security Officer	Initial release. Remediation for POAM-010 (CM-6).

Approval

Role	Name	Date approved
Information Security Officer	Daniel Okafor (fictional)	2026-11-06
Director of IT (System Owner)	Director of IT (fictional)	2026-11-06

Approval recorded 2026-11-06, after the DC01 assessment. The approvers are fictional people in a fictional organization. This standard is remediation for POAM-010 and was not in place during the assessment.